

A Practical Guide to **DORA** Certification

Master the Digital Operational Resilience Act
Through Simple Explanations and Real-World Examples



Digital
Operational
Resilience
Act



Understand
DORA
Requirements



Practical
Examples



Real-World
Scenarios



Exam
Focused



AUTHOR

Nouredine Kanzari

Cybersecurity Expert | GRC Professional | PECB Certified Trainer

About the author

Noureddine Kanzari is a cybersecurity expert with an extensive background in IT risk management and cybersecurity instruction. With a diverse range of certifications that includes being a PECB Certified Trainer, DORA Senior Lead Manager, NIST Cybersecurity Consultant, Senior Lead Incident Manager, Senior Lead SOC 2 Analyst, Data Protection Officer (DPO), DORA Senior Lead Manager, ISO 42001 Senior Lead Auditor, ISO 42001 Senior Lead Implementer, Senior Lead SCADA Security Manager, ISO 22301 Senior Lead Implementer, ISO 22301 Senior Lead Auditor, EBIOS Risk Manager, ISO 27005 Senior Lead Risk Manager, ISO 27001 Senior Lead Implementer, ISO 27001 Senior Lead Auditor, Cisco Certified Specialist in Security Core and Enterprise Core, NSE4 Network Security Professional, Palo Alto Instructor, Devops Tools Engineer, LPIC-3 Enterprise Professional Security, LPIC-3 Enterprise Professional Virtualization & High Availability, LPIC-2, LPIC-1, Suse Certified Linux Administration, and a Certified Security Auditor in computer security,

Noureddine Kanzari's professional journey is characterized by a series of impactful roles and accomplishments. Throughout his career, he has held various pivotal positions, including:

Chief Information Security Officer (CISO)

Audit Team Leader

Cybersecurity Instructor

Technical Manager

Training Manager

His extensive experience and leadership have contributed significantly to enhancing cybersecurity practices, risk management strategies, and organizational resilience.

Contents

1. What is DORA?	4
2. Why was DORA created?	5
3. Why is ICT resilience important?	6
4. Financial institutions depend on third-party ICT providers	7
5. Why are third-party risks dangerous?	8
6. What happens if ICT risks are poorly managed?	9
7. Cascading failures	10
8. Who Is Affected by DORA?	11
9. The Objectives of DORA	16
10. Risk Management under DORA	22
11. Enterprise Risk Management	28
12. DORA Third-Party Risk Management	35
13. Resilience Testing under DORA	46
14. DORA Implementation Plan for Resilience Testing	54
15. DORA ICT Incident Management	59
16. Information Sharing	64

1. What is DORA?

DORA stands for Digital Operational Resilience Act.

It is a European Union (EU) regulation created to improve cybersecurity and digital resilience in the financial sector.

- It entered into force on 16 January 2023.
- It became mandatory on 17 January 2025 for organizations within its scope.

Example

Imagine a bank's online banking system is attacked by hackers.

Without DORA:

- Customers cannot access their accounts.
- Payments stop working.
- Trust in the bank decreases.

With DORA:

- The bank is prepared.
- Backup systems are available.
- The attack is detected quickly.
- Services continue with minimal interruption.

2. Why was DORA created?

Today's financial organizations depend almost entirely on technology.

Without ICT, banks cannot:

- process payments
- transfer money
- issue credit cards
- approve loans
- manage customer accounts

Example

Imagine Visa's payment network stops working for one hour.

Millions of people cannot:

- pay in supermarkets
- buy fuel
- shop online
- withdraw money

One IT incident can affect millions of customers.

That is exactly why DORA exists.

3. Why is ICT resilience important?

Resilience means the ability to continue operating even when something goes wrong.

- It does **not** mean preventing every attack.
- It means:
- detect the incident
- respond quickly
- recover rapidly
- continue providing services

Example

- A bank suffers a ransomware attack.
- Without resilience:
- all systems stop
- customer data becomes unavailable
- business stops for several days
- With resilience:
- backups are restored
- infected servers are isolated
- customers continue using online banking
- only a small disruption occurs
- DORA requires financial organizations to become resilient.

4. Financial institutions depend on third-party ICT providers

Modern financial organizations no longer build everything themselves.

Instead, they outsource many IT services.

Examples include:

- Microsoft Azure
- Amazon Web Services (AWS)
- Google Cloud
- Salesforce
- Oracle
- SAP

These companies are called ICT third-party service providers.

Example

A bank stores its applications on Microsoft Azure.

If Azure experiences a major outage:

- online banking may stop
- mobile banking may fail
- customers cannot access their money

Although the problem is at Azure, the bank is still responsible for serving its customers.

Therefore, DORA requires banks to carefully manage their ICT providers.

5. Why are third-party risks dangerous?

Sometimes the weakest point is **not the bank itself**, but one of its suppliers.

Example

- A small software company develops the bank's mobile application.
- The software company has poor cybersecurity.
- Hackers compromise the supplier.
- The hackers then use that supplier to attack the bank.
- This is called a third-party risk or **supply chain risk**.
- DORA requires financial institutions to:
 - assess supplier risks
 - monitor suppliers continuously
 - include security requirements in contracts
 - regularly review supplier performance

Many technology companies are not banks. Therefore, they are not automatically subject to financial regulations.

Example

A cloud provider may have excellent technical capabilities but may not follow banking-specific security requirements. This creates a security gap. DORA introduces stronger oversight for critical ICT providers to reduce this gap.

6. What happens if ICT risks are poorly managed?

Poor ICT risk management can have serious consequences. Examples include:

Cyberattack

Hackers encrypt the bank's servers.

Result:

- customers cannot access accounts
- transfers stop
- ATMs stop working

Cloud outage

The cloud provider becomes unavailable.

Result:

- online banking becomes unavailable
- payment systems stop

Data breach

Customer information is stolen.

Result:

- privacy violations
- financial fraud
- legal penalties
- loss of customer trust

Software update failure

A faulty software update crashes critical banking systems.

Result:

- payment processing stops
- customer services become unavailable

7. Cascading failures

One organization's failure can affect many others.

This is called a cascading failure.

Example

A large payment provider suffers a cyberattack.

As a result:

- Bank A cannot process payments.
- Bank B cannot receive transfers.
- Online shops cannot accept payments.
- Customers cannot buy products.
- Businesses lose money.

One incident spreads across the entire financial ecosystem like falling dominoes.

DORA aims to prevent this type of chain reaction.

8. Who Is Affected by DORA?

The main goal of DORA (Digital Operational Resilience Act) is to make sure that the European financial sector can continue operating even during cyberattacks, IT failures, or other digital disruptions.

But who exactly must comply with DORA?

The answer is not only banks. DORA applies to many organizations that either provide financial services or support the financial sector through important ICT (Information and Communication Technology) services.

1. Banks and Credit Institutions

Banks are among the most important organizations covered by DORA.

People use banks every day to:

- keep their money,
- transfer funds,
- receive salaries,
- pay bills,
- use credit cards,
- apply for loans.

If a bank's IT systems stop working because of a cyberattack, millions of customers may be unable to access their money.

Example

Imagine a ransomware attack encrypts a bank's servers.

Customers cannot:

- withdraw cash,
- pay with their bank cards,
- access online banking,
- transfer money.

This could create panic and seriously affect the economy.

DORA requires banks to prepare for these situations by implementing strong cybersecurity, backup systems, incident response plans, and regular resilience testing.

2. Insurance Companies

Insurance companies are also covered by DORA.

Their digital systems manage:

- customer policies,
- claims,
- payments,
- contracts,
- personal information.

If these systems become unavailable, customers may not receive compensation when they need it most.

Example

A customer has a car accident.

The insurance company's systems are unavailable because of a cyberattack.

The customer cannot:

- declare the accident,
- upload documents,
- receive reimbursement.

DORA helps ensure that insurance companies can continue providing these essential services.

3. Investment Firms

Investment firms help customers buy and sell:

- stocks,
- bonds,
- ETFs,
- mutual funds,
- other financial products.

These organizations process thousands or even millions of transactions every day.

Example

An investor wants to sell shares during a market crash.

If the investment platform is unavailable because of an IT outage, the investor may lose a significant amount of money.

DORA requires investment firms to build resilient systems that remain available during disruptions.

4. Payment Service Providers

Payment service providers allow people and businesses to send and receive money electronically.

Examples include:

- online payment platforms,
- electronic money institutions,
- payment processing companies.

Example

A company wants to pay salaries on the last day of the month.

A cyberattack interrupts the payment platform.

Employees do not receive their salaries on time.

This is exactly the type of disruption DORA aims to prevent.

5. Financial Market Infrastructures

These organizations operate the core infrastructure of financial markets.

Examples include:

- stock exchanges,
- trading platforms,
- central securities depositories,
- clearing houses.

Although most people never interact with them directly, they are essential for the financial system.

Example

Every time investors buy or sell shares, these infrastructures ensure that the transaction is completed correctly.

If they stop working, financial markets may also stop functioning.

6. Critical ICT Third-Party Providers

This is one of the most important ideas introduced by DORA.

Financial institutions increasingly depend on external technology companies.

These companies provide services such as:

- cloud computing,
- data storage,
- cybersecurity,
- software platforms,
- data analytics,
- artificial intelligence.

Some well-known cloud providers include:

- Microsoft Azure,
- Amazon Web Services (AWS),
- Google Cloud Platform (GCP).

Example

A bank stores its online banking application on Microsoft Azure.

If Azure experiences a major outage, customers may lose access to online banking.

Although the bank did not directly cause the problem, the disruption still affects customers.

For this reason, DORA also places requirements on **critical ICT providers**, because the resilience of financial institutions depends heavily on them.

7. Outsourcing Service Providers

Many financial organizations outsource important activities to external companies.

Examples include:

- IT support,
- software development,

- managed security services,
- data centers,
- disaster recovery services,
- customer support.

Example

A bank outsources its Security Operations Center (SOC) to an external cybersecurity company.

If this company fails to detect cyberattacks, the bank may also be affected.

DORA therefore requires financial institutions to carefully manage risks related to outsourcing.

8. Regulators and Supervisory Authorities

DORA is also important for regulators.

Their role is to verify that organizations correctly apply DORA's requirements.

They perform activities such as:

- audits,
- inspections,
- compliance reviews,
- incident reporting supervision,
- resilience assessments.

Example

A national financial authority may inspect a bank to verify that:

- cyber risks are managed,
- incident response plans exist,
- resilience tests are performed,
- third-party providers are properly monitored.

9. The Objectives of DORA

1. ICT Risk Management

Goal

- Every financial organization must identify, assess, reduce, and continuously monitor its ICT risks.
- In simple words:
- Know your IT risks before they become problems.

Examples

- A ransomware attack encrypts the company's servers.
- An employee accidentally deletes an important database.
- A cloud server suddenly becomes unavailable.
- A software update causes all online banking services to stop.
- Instead of waiting for these events to happen, DORA requires organizations to prepare in advance.
- They should:
- identify possible risks,
- evaluate their impact,
- implement security controls,
- regularly review and improve their protection.

Example

- A bank discovers that its customer database is not backed up.
- Instead of waiting until the database crashes, it creates daily backups and tests them regularly.
- This is ICT Risk Management.

2. ICT Third-Party Risk Management

Goal

- Many organizations rely on external suppliers for cloud services, software, payment systems, cybersecurity, or data hosting.
- If a supplier has a problem, the organization can also suffer.
- DORA requires organizations to manage the risks coming from these third parties.

Examples

An organization uses:

- Microsoft Azure for cloud hosting
- AWS for backup
- Google Workspace for email
- A cybersecurity company for monitoring

If Azure experiences a major outage, the bank's online services may also stop working. Therefore, organizations should:

- evaluate suppliers before signing contracts,
- include security requirements,
- monitor supplier performance,
- prepare alternative solutions if a supplier fails.

Example

- A payment provider stores all customer data in one cloud provider.
- To reduce the risk, it also prepares a backup environment with another provider.

3. ICT Resilience Testing

Goal

- Organizations should regularly test whether their security measures actually work.
- Think of it like practicing a fire drill before a real fire happens.

Examples of resilience testing

- Penetration Testing
 - Ethical hackers try to break into the systems.
- Vulnerability Assessments
 - Security tools search for known weaknesses.
- Disaster Recovery Tests
 - Verify whether backups can really restore the systems.
- Business Continuity Tests
 - Ensure critical services continue during an outage.

Example

- An ethical hacker successfully enters the company's network using a weak password.
- The organization fixes the problem before a real attacker discovers it.

4. ICT Incident Management

Goal

- Cyber incidents will happen.
- DORA requires organizations to detect them quickly, respond efficiently, recover rapidly, and learn from every incident.

Examples of ICT incidents :

- Malware infection
- Phishing attack
- Data breach
- Distributed Denial-of-Service (DDoS) attack
- Cloud service outage
- Server failure
- Organizations should have:
 - an incident response team,
 - clear response procedures,
 - monitoring tools,
 - communication plans,
 - recovery plans.

Example

- A phishing email steals an employee's password.
- The security team immediately:
 - blocks the account,
 - resets the password,
 - investigates the attack,
 - informs management,
 - reports the incident if required.

5. ICT Information Sharing

Goal

- Financial organizations should not fight cybercriminals alone.
- Instead, they should securely share cyber threat information with other organizations.
- This helps everyone become better protected.

Examples

- A bank discovers a new phishing campaign targeting customers.
- Instead of keeping the information private, it shares:
 - attacker IP addresses,
 - malicious domains,
 - malware signatures,
 - attack techniques.
- Other banks can immediately block the same attack.

Real-life example

- One insurance company detects a new ransomware variant.
- It shares the indicators of compromise (IOCs) with other financial institutions, allowing them to strengthen their defenses before being attacked.

6. Oversight of Critical ICT Third-Party Providers

Goal

- Some ICT providers are so important that many financial institutions depend on them.
- Examples include large cloud providers and critical technology vendors.
- DORA introduces additional supervision of these critical providers.
- Organizations must continuously monitor whether these providers remain secure and reliable.

Examples

- Critical providers may include:
- cloud providers,
- payment infrastructure providers,
- major cybersecurity service providers,
- large data hosting companies.

Organizations should:

- regularly review supplier security,
- assess operational risks,
- verify compliance,
- prepare contingency plans.

Example

- If a cloud provider suffers a major cyberattack, many banks could be affected simultaneously.
- DORA therefore requires stronger oversight and monitoring of these critical providers.

10. Risk Management under DORA

One of the most important requirements of DORA (Digital Operational Resilience Act) is that every financial organization (such as banks, insurance companies, investment firms, and payment providers) must have an ICT Risk Management Framework.

An ICT Risk Management Framework is simply a structured way to identify, analyze, reduce, monitor, and report risks related to information technology (IT).

1. Establish and Document an ICT Risk Management Framework

The framework must be:

- Established (officially created)
- Documented (written in policies and procedures)
- Approved by management
- Integrated into the company's overall risk management process

This means that cybersecurity risks should not be managed separately. They must become part of the organization's overall risk governance.

Example

A bank already manages many types of risks:

- Financial risk
- Legal risk
- Compliance risk
- Operational risk

DORA requires the bank to also manage ICT (technology) risks in the same governance process.

Instead of having cybersecurity work alone, it becomes part of the company's global risk management.

2. Identify ICT Risks

The organization must continuously identify everything that could negatively affect its ICT systems.

Examples of ICT Risks

- Hacker attacks
- Ransomware
- Phishing emails

- Cloud service outage
- Database failure
- Server crash
- Power outage
- Employee mistake
- Data leak
- Software vulnerability

Example

Imagine a bank uses Microsoft Azure.

Possible ICT risks include:

- Azure becomes unavailable for two hours.
- A hacker steals customer information.
- A software update causes the banking application to stop working.

All these risks must be identified.

3. Assess ICT Risks

Once risks are identified, the organization evaluates:

- How likely is this risk?
- What would happen if it occurs?

This is called Risk Assessment.

Example

Risk:

"A ransomware attack encrypts customer databases."

Questions:

- Is this likely?
- How much damage would it cause?

If the answer is:

- High probability
- Very high impact

Then it becomes a High Risk.

4. Prioritize ICT Risks

Not all risks are equally important.

The organization must decide which risks require immediate attention.

Risk	Priority
Temporary printer failure	Low
Employee forgot password	Low
Banking application unavailable	High
Customer data leak	Critical
Ransomware attack	Critical

The most dangerous risks are handled first.

Think of it like a hospital emergency room:

- A patient with a broken finger waits.
- A patient having a heart attack is treated immediately.

Risk management works the same way.

5. Implement Risk Mitigation Measures

- After identifying risks, the organization must reduce them.
- This is called Risk Mitigation.
- DORA expects organizations to implement different types of security controls.

Preventive Controls

- These controls try to stop incidents before they happen.

Examples:

- Multi-Factor Authentication (MFA)
- Firewall
- Antivirus
- Employee security awareness training
- Strong passwords
- Data encryption

Example

Without MFA:

- A hacker steals an employee password and logs into the system.

With MFA:

- The hacker still needs the employee's phone.
- The attack fails.

Detective Controls

These controls detect attacks quickly.

Examples:

- SIEM
- Security monitoring
- Log monitoring
- Intrusion Detection System (IDS)
- Security alerts

Example

A hacker logs in at 3:00 AM from another country.

The monitoring system detects unusual activity and immediately alerts the Security Operations Center (SOC).

The attack is discovered before major damage occurs.

6. Monitor Risks Continuously

Risk management is not a one-time activity. Technology changes every day. New vulnerabilities appear. New cyberattacks are discovered. Therefore, organizations must monitor risks continuously. Example :

Every week:

- Scan servers for vulnerabilities.
- Review security logs.
- Check failed login attempts.
- Monitor cloud services.
- Verify backups.

Risk management never stops.

7. Report ICT Risks to Management

One major DORA requirement is risk reporting.

Senior management cannot make good decisions if they do not know the risks.

Regular reports should explain:

- Current ICT risks
- Risk level
- New vulnerabilities
- Security incidents
- Planned corrective actions

Example

A monthly report may state:

- 3 Critical Risks
- 7 High Risks
- 15 Medium Risks

One critical risk:

"The online banking application uses outdated software with a known vulnerability."

Management can then decide:

- Patch immediately.
- Purchase additional security tools.
- Increase the security budget.

Good reporting supports risk-informed decision-making.

8. Escalate Critical ICT Risks

Some risks are so serious that they cannot wait until the next meeting.

DORA requires an Escalation Process.

This means there must be clear rules explaining:

- Who should be informed?
- How quickly?
- Who makes the decision?
- What actions must be taken?

Example

A ransomware attack starts encrypting banking servers.

The process may be:

1. Security team detects the attack.
2. SOC informs the CISO immediately.
3. CISO informs executive management.
4. Incident Response Team is activated.
5. Regulators are notified if required.
6. Recovery begins using backups.

Without an escalation process, valuable time could be lost.

Identify Risks



Assess Risks



Prioritize Risks



Reduce Risks (Preventive + Detective Controls)



Monitor Continuously



Report to Management



Escalate Critical Risks



Improve Continuously

11. Enterprise Risk Management

Enterprise Risk Management (ERM) is the process that helps an organization identify, understand, manage, and monitor all the risks that could prevent it from achieving its business objectives.

Just like a doctor regularly checks your health to prevent diseases, ERM regularly checks the company's risks before they become serious problems.

Example

A bank wants to provide online banking services 24/7.

ERM helps answer questions such as:

- What if hackers attack our systems?
- What if our cloud provider fails?
- What if employees make mistakes?
- What if a natural disaster shuts down our data center?

Instead of waiting for these events to happen, ERM prepares the organization in advance.

Corporate Governance defines where the company wants to go (its strategy and objectives).

Enterprise Risk Management helps ensure the company reaches those objectives safely.

Think about driving a car:

- Corporate Governance = Choosing your destination
- Enterprise Risk Management = Avoiding accidents during the trip

Without ERM, even the best business strategy can fail because unexpected risks are not managed.

Three Main Types of Business Risks

Business risks are usually divided into three categories.

A. Preventable Risks

The Risks that the organization can avoid. These risks usually come from internal mistakes or poor practices. If the company follows good procedures and security controls, these risks can often be prevented.

Examples

- An employee accidentally sends confidential customer information to the wrong person.
- An employee clicks on a phishing email.
- Weak passwords allow hackers to access company systems.
- A laptop containing sensitive data is stolen because it was not encrypted.

- Employees ignore security policies.

How can we reduce these risks?

- Employee awareness training
- Multi-Factor Authentication (MFA)
- Strong password policies
- Encryption
- Security monitoring
- Access controls

Example

- A company trains all employees to recognize phishing emails.

Result:

- Employees stop clicking malicious links.
- ➔ The risk is greatly reduced.

Strategic Risks

Risks created by business decisions.

Strategic risks happen because management deliberately chooses one option instead of another.

Sometimes the company accepts a higher risk because it believes the business benefit is greater.

Example 1

A company decides not to replace old Windows XP computers because buying new hardware would cost €2 million.

Management says:

"We accept the cybersecurity risk because upgrading is too expensive."

This is a strategic decision.

Example 2

A company delays software updates to avoid interrupting production.

The advantage:

- No production downtime.

The disadvantage:

- Systems remain vulnerable to hackers.

Again, this is a strategic risk.

Example 3

A bank launches a new mobile banking application very quickly to beat competitors.

Because development is rushed:

- Some security tests are skipped.

Management accepts this additional risk to gain market advantage.

This is another strategic risk.

External Risks

The Risks outside the organization's control. These risks come from outside the company.

The organization cannot prevent them, but it should prepare for them.

Examples

- Earthquakes
- Floods
- Fires
- Power outages
- Pandemics
- War
- New government regulations
- Supplier bankruptcy
- Cloud provider outage

Cloud Example

Imagine your company stores all its applications in Microsoft Azure. If Azure suffers a major outage, your customers may no longer access:

- Online banking
- Shopping websites
- Business applications

The outage is outside your control. Therefore, it is an external risk.

Another Example

A software supplier suddenly goes bankrupt.

The supplier stops providing:

- Security updates
- Technical support

Your company must quickly find another supplier.

Again, this is an external risk.

Cybersecurity Risks are Part of Enterprise Risk Management

Modern companies depend heavily on technology. Because of this, cybersecurity is now a major part of Enterprise Risk Management. Cyber risks should never be managed separately.

They must be integrated into the organization's overall risk management process.

Examples of Cyber Risks

- Ransomware attacks
- Data breaches
- Phishing attacks
- Insider threats
- Cloud misconfigurations
- DDoS attacks
- Malware infections
- Third-party supplier compromise

Banking Example

A ransomware attack encrypts all customer databases.

Customers cannot:

- Transfer money
- Check account balances
- Use online banking

This becomes:

- A cybersecurity risk
- An operational risk

- A financial risk
- A reputational risk

One cyberattack creates several business risks at the same time.

The Enterprise Risk Management Process

Organizations usually manage risks using five simple steps.

Step 1 : Identify Risks : "What could go wrong?"

Examples

- Hackers
- Floods
- Human mistakes
- Supplier failures
- Hardware failures

Step 2 : Analyze Risks

Evaluate each risk by asking two questions:

How likely is it ?

- Low
- Medium
- High

What would be the impact ?

- Low
- Medium
- High

Example

Risk: Ransomware attack

Likelihood: High

Impact: Very High

Step 3: Prioritize Risks

Not every risk needs immediate attention. Organizations first treat the risks that have:

- High likelihood
- High impact

Risk	Priority
Ransomware attack	High
Printer failure	Low
Employee phishing	High
Office coffee machine failure	Very Low

Step 4 : Respond to Risks

Organizations have four common ways to deal with a risk.

1. Mitigate: Reduce the risk.

Example:

Install firewalls and antivirus software.

2. Accept: Do nothing because the risk is considered acceptable.

Example:

Accept a very small risk because fixing it would cost too much.

3. Transfer: Move the financial impact to another party.

Example:

Buy cyber insurance.

4. Avoid: Stop the activity creating the risk.

Example:

Do not store sensitive customer data if it is not necessary.

Monitor Risks

Risk management never ends. Business environments constantly change.

New technologies, regulations, threats, and suppliers create new risks.

Organizations should regularly review:

- Existing risks
- Security controls
- Risk levels

- Business changes

Example

Last year: The risk of AI-generated phishing emails was low.

Today:

- AI can generate extremely convincing phishing emails.
- The likelihood has increased.
- The company updates its risk assessment and strengthens employee training.

12. DORA Third-Party Risk Management

Most financial organizations do not manage all their IT systems by themselves. They rely on ICT third-party providers, such as cloud providers, software vendors, cybersecurity companies, or managed service providers.

Examples:

- A bank stores its data in AWS or Microsoft Azure.
- An insurance company uses Salesforce to manage customers.
- A fintech company hires an external SOC (Security Operations Center) to monitor cyberattacks.

If one of these providers is attacked or stops working, the financial organization may also be affected.

Example:

If Microsoft Azure has a major outage, a bank hosting its online banking platform on Azure may no longer be able to serve its customers.

That is why DORA requires financial organizations to carefully manage ICT third-party risks.

Perform a Risk Assessment Before Choosing a Provider

Before signing a contract, DORA requires organizations to evaluate the provider's cybersecurity and operational resilience. The goal is to answer questions such as:

- Is this provider secure?
- Can it protect our confidential data?
- Can it recover quickly after a cyberattack?
- Does it comply with security standards?

Example

A bank wants to use a cloud provider. Before signing the contract, the bank sends a security questionnaire asking:

- Are you ISO 27001 certified ?
- Do you encrypt customer data ?
- Do you have Multi-Factor Authentication (MFA) ?
- How do you detect cyberattacks ?
- Do you have a disaster recovery plan ?
- Have you suffered any major security incidents ?

The bank reviews the answers and decides whether the provider represents a Low, Medium, or High risk.

Make a Risk-Based Decision

Receiving answers is not enough. DORA requires organizations to analyze the answers and decide whether the provider is acceptable.

Example

Provider A answers:

- ISO 27001 Certified
 - Data encrypted
 - 24/7 Security Operations Center
 - Disaster Recovery tested every year
- ➔ Low Risk

Provider B answers:

- No security certification
 - No encryption
 - No disaster recovery plan
- ➔ High Risk

The organization may decide not to work with Provider B because the risk is too high.

Define Security Requirements in the SLA

An SLA (Service Level Agreement) defines the expected level of service.

Under DORA, the SLA should also include security and resilience requirements, not only technical performance.

The contract should clearly specify:

- System availability (for example, 99.9% uptime)
- Maximum recovery time after an incident
- Incident reporting deadlines
- Backup frequency
- Security responsibilities

- Business continuity requirements

Example

A cloud provider promises:

- 99.99% availability
- Report any cyber incident within 4 hours
- Restore services within 2 hours
- Daily encrypted backups
- These commitments become part of the contract.

Continuously Monitor the Provider

DORA requires organizations to monitor ICT providers throughout the entire relationship. Do not assume the provider will always remain secure. Regular monitoring may include:

- Reviewing security reports
- Checking compliance certificates
- Monitoring service availability
- Reviewing audit reports
- Tracking security incidents
- Monitoring SLA performance

Example

Every quarter, a bank checks whether its cloud provider:

- Still holds ISO 27001 certification
- Meets uptime commitments
- Has experienced any cyberattacks
- Continues to comply with DORA requirements

Prepare an Exit Strategy

One day, the provider may:

- Stop its services
- Increase prices significantly
- Experience repeated cyberattacks
- Lose regulatory approval
- Go bankrupt

DORA requires organizations to prepare for this situation before it happens. This is called an Exit Strategy.

Example

- A bank stores customer data in AWS.
- If AWS becomes unavailable for a long period, the bank already has a documented plan to migrate its systems to Microsoft Azure.
- Because the migration plan has been prepared in advance, business disruption is minimized.

Create a Contingency Plan

A Contingency Plan explains what to do if the provider suffers an unexpected disruption.

Example

If the cloud provider becomes unavailable:

- Activate backup systems.
- Switch to a secondary data center.
- Restore data from backups.
- Inform customers.
- Continue critical banking services.
- The objective is to keep essential services running even when the provider experiences problems.

Include DORA Clauses in Contracts

DORA requires contracts with ICT providers to include specific legal clauses.

The contract should clearly state:

- Security responsibilities
- Incident notification requirements
- Right to audit the provider
- Regulatory access rights
- Data protection obligations
- Business continuity requirements
- Exit procedures
- Termination conditions

Example

The contract may state:

- "The financial institution has the right to audit the provider's security controls once per year."
- This allows the organization to verify that the provider continues to meet DORA requirements.

Third-Party Risk Management Implementation Plan

DORA does not only require financial organizations to manage ICT third-party risks, it also expects them to follow a structured process throughout the entire relationship with suppliers.

Think of an ICT provider as a company that offers important IT services to your organization, such as:

- Cloud services (AWS, Microsoft Azure)
- Cybersecurity services
- Software vendors (SAP, Salesforce)
- Managed Service Providers (MSPs)
- Data centers
- Payment service providers

The implementation plan covers the supplier's entire lifecycle:

Before signing the contract → During the partnership → If something goes wrong → When the contract ends

Step 1: Assess the Risks Before Choosing a Supplier

Before working with any ICT provider, you must understand how risky that provider is. Ask yourself questions such as:

- Is the supplier secure?
- Have they experienced cyberattacks before?
- Can they continue operating during an incident?
- Do they comply with DORA and other regulations?
- Will they protect our sensitive data?

Example

A bank wants to move customer data to a cloud provider. Before signing the contract, the bank:

- sends a security questionnaire
- reviews ISO 27001 certification
- requests penetration test reports
- evaluates financial stability
- checks previous security incidents
- Only after this assessment does the bank decide whether the supplier is trustworthy.
- This should always be the first major step.

Step2: Create Strong Contracts (SLAs and Security Clauses)

A contract should define much more than the service price. DORA expects contracts to clearly describe security responsibilities. The contract should include:

- Security requirements
- Availability targets (99.9% uptime, for example)
- Incident notification deadlines
- Recovery objectives
- Audit rights
- Compliance with DORA
- Data protection responsibilities

Example

A cloud provider promises:

- 99.95% service availability
- Notify the bank within 2 hours after detecting a cyber incident
- Participate in disaster recovery exercises
- Allow regulatory audits
- These commitments become part of the Service Level Agreement (SLA).

Step 3 : Continuously Monitor Suppliers

- Risk assessment is **not a one-time activity**.
- A supplier that was secure last year may become risky today.
- DORA requires organizations to continuously monitor ICT providers.
- Monitoring may include:
 - Security scorecards
 - Regular audits
 - Compliance reviews
 - Vulnerability reports
 - Performance measurements
 - Incident reports

Example

- A software supplier suffers a ransomware attack.

- Because the company continuously monitors suppliers, it quickly learns about the incident, evaluates the impact, and requests corrective actions before the supplier resumes normal operations.
- Continuous monitoring helps identify problems before they become major business risks.

Step4 : Continuously Monitor Suppliers

Risk assessment is not a one-time activity. A supplier that was secure last year may become risky today. DORA requires organizations to continuously monitor ICT providers. Monitoring may include:

- Security scorecards
- Regular audits
- Compliance reviews
- Vulnerability reports
- Performance measurements
- Incident reports

Example

A software supplier suffers a ransomware attack. Because the company continuously monitors suppliers, it quickly learns about the incident, evaluates the impact, and requests corrective actions before the supplier resumes normal operations. Continuous monitoring helps identify problems before they become major business risks.

Step5 : Prepare an Exit Strategy

- One day, you may need to stop working with a supplier.
- Reasons could include:
 - Poor security
 - Repeated outages
 - Bankruptcy
 - Contract termination
 - Regulatory non-compliance
- DORA requires organizations to prepare for this possibility **before it happens**.
- An exit strategy should explain:
 - How data will be recovered
 - How services will be transferred
 - Which supplier will replace the current one
 - How business operations will continue

Example

- A bank uses Cloud Provider A.
- If that provider suddenly stops operating, the bank already has a plan to migrate all applications to Cloud Provider B within two weeks.
- Without an exit strategy, business operations could stop completely.

Step 6: Include Audit and Regulatory Rights

Financial organizations and regulators must be able to verify that suppliers comply with DORA. Contracts should therefore include clauses allowing:

- Security audits
- Compliance inspections
- Evidence requests
- Regulatory reviews

Example

The financial regulator wants to verify that a cloud provider encrypts customer data. Because the contract includes audit rights, the bank can request documentation and perform an audit whenever necessary.

Step 7: Maintain a Central Register of ICT Suppliers

Managing suppliers with spreadsheets quickly becomes difficult. Organizations should maintain a centralized register containing information such as:

- Supplier name
- Services provided
- Risk level
- Contract expiration date
- Audit results
- Security incidents
- Performance indicators

Example

Instead of searching through emails, the procurement and security teams open one centralized dashboard showing every ICT supplier and its current risk status. This provides a complete overview of third-party risk.

Step 8: Regularly Review Contracts

Cyber threats constantly evolve. A contract signed three years ago may no longer provide sufficient protection. Organizations should periodically review supplier agreements to ensure they still reflect:

- New cyber threats
- Updated DORA requirements
- New business needs
- Technology changes

Example

When DORA introduces new reporting requirements, the organization updates supplier contracts to ensure providers report cyber incidents according to the latest rules.

Step 9: Include Suppliers in Incident Response and Business Continuity Plans

Many critical business services depend on external ICT providers. If a supplier experiences a cyberattack, your organization will also be affected. Therefore, suppliers should be included in:

- Incident Response Plans
- Business Continuity Plans (BCP)
- Disaster Recovery Plans (DRP)

Everyone should clearly understand:

- Who contacts the supplier?
- Who manages communication?
- Who restores the service?
- Who reports the incident to regulators?

Example

A ransomware attack affects the company's cloud provider. Because the provider participates in the organization's incident response plan:

- Security teams immediately contact each other.
- Recovery procedures begin.
- Backup systems are activated.
- Customers experience minimal disruption.

Step 10 : Train Internal Teams

Managing third-party risk is not only the responsibility of the IT or cybersecurity department.

Many departments interact with ICT suppliers. Training should therefore include:

- Procurement
- Legal
- Risk Management
- Compliance

- Information Security
- Business Managers

Everyone should understand:

- DORA requirements
- Supplier risk assessment
- Security obligations
- Contract requirements
- Monitoring responsibilities

Example

The procurement team wants to purchase a new SaaS application. Because they received DORA training, they know they cannot sign the contract immediately. Instead, they first ask the cybersecurity team to perform the required risk assessment.

13. Resilience Testing under DORA

DORA (Digital Operational Resilience Act) does not only require financial institutions to protect their ICT systems, it also requires them to **prove** that these systems can continue operating during cyberattacks, technical failures, or unexpected disruptions.

Think of resilience testing like a **fire drill**. A company does not wait for a real fire before checking whether emergency exits work. Instead, it performs regular drills to ensure everyone knows what to do.

Similarly, DORA requires organizations to regularly test their ICT systems before a real cyber incident happens.

Regular Resilience Testing

Organizations must regularly test the resilience of their systems. The objective is to verify that systems can:

- continue operating during incidents,
- resist cyberattacks,
- recover quickly,
- minimize disruption to customers.

Example

Imagine an online banking application. The bank simulates the failure of one application server. The test verifies:

- Can customers still log in?
- Can they still transfer money?
- Does another server automatically replace the failed one?
- How long does recovery take?
- If everything continues working normally, the system is considered resilient.

Test Critical Systems

DORA places special attention on critical ICT systems, meaning systems whose failure could seriously affect financial services.

Examples include:

- Online banking platforms
- Payment processing systems
- ATM networks
- Trading platforms
- Customer authentication systems

- Fraud detection systems

These systems must be tested regularly because even a short outage could impact thousands of customers.

Example

If a payment gateway stops working for only five minutes, thousands of credit card payments may fail. DORA requires testing these systems before such failures occur.

Penetration Testing

Penetration testing (Pen Test) is a controlled cyberattack performed by ethical hackers. The objective is to discover vulnerabilities before real attackers do. Instead of waiting for hackers to attack, the organization hires security professionals to attack its own systems safely.

Example

An ethical hacker attempts to:

- steal customer accounts,
- bypass authentication,
- exploit SQL Injection,
- upload malicious files,
- gain administrator privileges.
- Every successful attack reveals a security weakness that must be corrected.

Think of penetration testing as hiring someone to try breaking into your house to check whether your doors and windows are secure.

Vulnerability Assessments

A vulnerability assessment searches for known security weaknesses in systems, applications, operating systems, and network devices.

Unlike penetration testing, it does not actively exploit vulnerabilities. Instead, it identifies and prioritizes them.

Example

A vulnerability scanner detects:

- Windows server missing security patches
- Outdated Apache version
- Weak TLS configuration
- Unsupported software
- Default passwords

The organization then evaluates:

- Which vulnerabilities are the most dangerous?

- Which should be fixed first?

Remediation Plans

Finding vulnerabilities is not enough. DORA requires organizations to correct them through an actionable remediation plan. The remediation plan should answer questions such as:

- What is the vulnerability?
- How serious is it?
- Who is responsible for fixing it?
- When will it be fixed?
- How will we verify the fix?

Example

Finding:

- SQL Injection vulnerability in the customer portal.

Remediation plan:

- Developer fixes the application code.
- Security team verifies the fix.
- New penetration test confirms the vulnerability no longer exists.

Ticket is closed.

Disaster Recovery Testing

A Disaster Recovery (DR) test verifies whether the organization can restore critical services after a major incident. The goal is to ensure business continuity.

Example

The company simulates:

- complete data center failure,
- ransomware attack,
- cloud outage,
- power loss,
- database corruption.

The test verifies:

- Can services be restored?
- How much data is lost?
- How long does recovery take?
- Are customers still served?

Backup Testing

Creating backups is not enough. DORA requires organizations to regularly verify that backups actually work. Many organizations discover during a real disaster that their backups are corrupted or incomplete.

Example

The IT team restores yesterday's backup. They verify:

- Can customer accounts be recovered?
- Are transactions complete?
- Are files readable?
- Is the restored application functional?

Only a successful restoration proves that backups are reliable.

Test Under Realistic Scenarios

DORA requires tests to be as realistic as possible. The objective is to simulate situations that could happen in real life.

Examples include:

- Ransomware attack
- Distributed Denial of Service (DDoS) attack
- Insider threat
- Cloud service outage
- Hardware failure
- Database corruption
- Network failure
- Human error
- Data center fire
- Power outage

The more realistic the scenario, the more useful the test.

Vulnerability Management

Vulnerability is a weakness in a computer system, application, server, or network that attackers could exploit to steal data, install malware, or disrupt business operations.

Vulnerability Management is the continuous process of finding these weaknesses, assessing how dangerous they are, fixing them, and ensuring they do not put the organization at risk.

This process is one of the key cybersecurity activities required by many international standards such as DORA, ISO/IEC 27001, and NIST. Although each framework may describe the process slightly differently, they all aim to achieve the same goal: reduce cybersecurity risks before attackers exploit vulnerabilities.

Steps of Vulnerability Management

Step 1: Identify Vulnerabilities

The first step is to discover security weaknesses. Organizations use different methods:

- Automated vulnerability scanners
- Penetration testing
- Security audits
- Vendor security advisories

Example 1

A company scans all its Windows servers using Nessus. The scanner finds that one server is missing Microsoft's latest security update. This missing update is a vulnerability.

Example 2

A web application scan discovers that the login page is vulnerable to SQL Injection. An attacker could use this weakness to access customer information.

Step 2 – Evaluate the Vulnerabilities

Finding vulnerabilities is not enough. The organization must understand:

- How serious is the vulnerability?
- What could happen if someone exploits it?
- Which systems are affected?
- Is the vulnerability already being exploited on the Internet?

Many organizations use the **CVSS (Common Vulnerability Scoring System)**. CVSS gives a score between **0 and 10**.

CVSS Score	Severity
0.1 – 3.9	Low
4.0 – 6.9	Medium
7.0 – 8.9	High
9.0 – 10	Critical

Example

A vulnerability receives a CVSS score of 9.8.

This means attackers can easily exploit it and completely take control of the affected server.

The company knows it is a very serious issue.

Step 3 : Prioritize the Vulnerabilities

Not every vulnerability needs to be fixed immediately. Organizations must decide which vulnerabilities are the most important. Priority depends on several factors:

- CVSS score
- Business impact
- Asset criticality
- Whether the vulnerability is publicly exploited
- Regulatory requirements (such as DORA)

Example 1

Two vulnerabilities both have a CVSS score of **8.5**. Server A hosts the company's public banking application. Server B is an unused test server. Even though both have the same score, Server A must be fixed first because it is much more important for the business.

Example 2

A vulnerability affects the payroll system. Even if its CVSS score is only **6.5**, the organization may treat it as a high priority because payroll contains sensitive employee information.

Step 4 : Remediate the Vulnerabilities

Now the organization fixes the vulnerabilities. The preferred solution is to install the official security patch provided by the software vendor.

Example

Microsoft releases a security update for Windows. The IT team installs the update on all affected servers. The vulnerability is now fixed.

Step 5: Report and Improve

Finally, the organization reports the results. Management needs to know:

- How many vulnerabilities were found?
- How many were fixed?
- Which critical vulnerabilities remain open?
- How quickly are vulnerabilities being resolved?
- Is the security posture improving?

These reports help management make better cybersecurity decisions and allocate resources where they are most needed.

Example

A monthly report shows:

- 250 vulnerabilities discovered
- 230 fixed
- 15 medium vulnerabilities still open
- 5 critical vulnerabilities waiting for vendor patches
- Management decides to assign additional engineers to speed up remediation.

Penetration Testing

Imagine you hire a professional ethical hacker to attack your company before a real hacker does. The goal is not to damage your systems, but to find security weaknesses (called vulnerabilities) before criminals discover them.

Example

Suppose your company has an online banking website. A penetration tester tries to:

- Log in without a password.
- Access another customer's account.
- Steal sensitive information.
- Bypass security protections.

If the tester succeeds, it means a real attacker could probably do the same thing. The company can then fix the problem before a cybercriminal exploits it.

Main objective: Discover security weaknesses before attackers do.

A penetration tester's job is similar to a building inspector. Imagine an inspector checks your house and finds:

- a broken door,
- an open window,
- faulty electrical wiring.

The inspector doesn't repair them. Instead, the inspector gives you a report explaining:

- what is wrong,
- how serious the problem is,
- how to fix it.

A penetration tester works exactly the same way. At the end of the engagement, you receive a report containing:

- all vulnerabilities found,
- their severity,
- evidence (screenshots or proof),
- recommendations for remediation.

Then your IT or security team fixes the issues.

14. DORA Implementation Plan for Resilience Testing

Imagine that your company is a bank. One day, a ransomware attack encrypts all your servers. Customers cannot transfer money, use mobile banking, or pay with their cards.

DORA asks a simple question:

"Can your organization continue operating during a cyberattack and recover quickly?"

To answer this question, DORA requires organizations to regularly test their ICT systems (servers, applications, cloud services, networks, databases, etc.) before a real incident happens.

Think of resilience testing like a fire drill.

- We don't wait for a real fire to see if people know how to escape.
- Similarly, we don't wait for a real cyberattack to know whether our IT systems can survive.

The goal is not only to find problems, but also to fix them before attackers exploit them.

Step 1: Regularly Test Critical ICT Systems

The first requirement is to regularly test the organization's critical ICT systems. Critical systems are the ones that the business cannot live without.

Examples

A bank:

- Online banking website
- ATM network
- Payment processing system

A hospital:

- Patient database
- Medical equipment network
- Emergency communication system

An airline:

- Flight booking platform
- Check-in system
- Baggage management system

DORA requires organizations to verify that these systems can:

- continue operating during disruptions,

- recover quickly after failures,
- protect customer data,
- maintain essential services.

Step 2 : Perform Penetration Testing

One important resilience test is penetration testing (pentesting). A penetration test is an authorized cyberattack performed by ethical hackers. Its objective is to discover vulnerabilities before real hackers do.

Example

An ethical hacker tries to:

- break into the online banking portal,
- steal customer information,
- bypass authentication,
- gain administrator access.

If the ethical hacker succeeds, the company has discovered a weakness that must be fixed.

Think of a penetration tester as someone hired to try breaking into your house so you know which doors and windows need stronger locks.

Step 3 : Perform Vulnerability Assessments

A vulnerability assessment is different from penetration testing.

It focuses on finding weaknesses, not exploiting them. Specialized security tools scan systems looking for issues such as:

- missing security patches,
- outdated software,
- weak passwords,
- insecure configurations,
- exposed network ports.

Example

The scanner discovers:

- Windows Server missing the latest security update.
- Apache web server is two years out of date.
- An administrator account still uses the password "Admin123".

The organization then prioritizes these vulnerabilities according to their risk.

Step 4: Create a Remediation Plan

Finding vulnerabilities is only the beginning. The real objective is to eliminate the risks.

For every issue discovered, the organization should define:

- Who will fix it?
- What needs to be done?
- When must it be completed?

Example

Finding	Owner	Deadline
Critical server not patched	Infrastructure Team	24 hours
Weak administrator password	IT Operations	Same day
Outdated firewall firmware	Network Team	3 days

Step 5: Test Backup and Disaster Recovery

Many organizations believe their backups work. However, they often discover the opposite during their first recovery test. DORA requires organizations to actually test their backups and disaster recovery procedures.

Example

A ransomware attack encrypts every production server. The company restores data from backups. The test verifies:

- Were backups available?
- Were they complete?
- How long did restoration take?
- Was any data lost?

Step 6: Track and Manage Test Results

Every resilience test should produce documented results. The organization should record:

- what was tested,
- what succeeded,
- what failed,
- identified risks,
- corrective actions,
- responsible owners,

- deadlines.

Example

After a penetration test:

Finding:

- SQL Injection vulnerability found on the customer portal.

Action:

- Development team must fix the vulnerability within five business days.

Status:

- Closed after verification.

This ensures that no findings are forgotten.

Step 7: Involve Multiple Teams

Cyber resilience is not only an IT responsibility. Many departments should participate.

Examples include:

- IT Operations
- Cybersecurity Team
- Risk Management
- Business Continuity Team
- Application Owners
- Cloud Team
- Network Team
- Business Managers
- Third-party suppliers (when necessary)

Example

Suppose the payment platform is tested. The participants might include:

- Security team performing the attack simulation.
- IT Operations monitoring servers.
- Business managers verifying that payments still work.
- Risk managers evaluating business impact.
- Everyone learns how to react during a real incident.

Step 8: Continuously Improve Testing

- Technology changes constantly.
- New applications, cloud services, AI systems, and cyber threats appear every year.
- Therefore, resilience testing procedures should also evolve.

Example

Last year: The company only tested on-premises servers.

This year: It also tests cloud workloads, AI applications, APIs, third-party SaaS services. Continuous improvement ensures that testing remains relevant.

Step 9: Use the Results to Improve the Entire Organization

The most valuable part of resilience testing is learning from the results. The findings should improve:

- Business Continuity Plans (BCP)
- Disaster Recovery Plans (DRP)
- Incident Response Plans
- ICT Risk Management
- Security controls
- Employee training
- Future resilience tests

Example

- A resilience test reveals that restoring the payment platform takes 8 hours, while the business objective is 2 hours. The organization then:
- upgrades backup infrastructure,
- improves recovery procedures,
- trains IT staff,
- performs another recovery test.

15. DORA ICT Incident Management

An incident is any unexpected event that affects the confidentiality, integrity, or availability of an organization's information and communication technology (ICT) systems.

Examples of ICT incidents include:

- A ransomware attack encrypting company files.
- A phishing email stealing employee passwords.
- An application becoming unavailable because of a server failure.
- A cloud service outage preventing customers from accessing online banking.
- A network attack slowing down company systems.

Under DORA (Digital Operational Resilience Act), every financial organization must have a structured process to detect, respond to, recover from, learn from, and report ICT incidents. The objective is to minimize business disruption and protect customers, financial services, and the stability of the financial sector.

Step 1: Create an ICT Incident Management Policy

The first DORA requirement is to establish, document, approve, and regularly review an ICT Incident Management Policy. Think of this policy as the organization's emergency playbook. It answers questions such as:

- What is considered an ICT incident?
- Who is responsible during an incident?
- How should incidents be reported?
- Who must be informed?
- How quickly should actions be taken?
- How are incidents closed and documented?

Without this policy, every employee may react differently during a cyberattack, causing confusion and delays.

Example

- A bank suffers a ransomware attack.

Because the Incident Management Policy already exists:

- The Security Operations Center (SOC) detects the attack.
- The Incident Response Team is automatically notified.
- The CISO is informed immediately.

- A crisis meeting is organized.
- Customers are protected while systems are restored.

Everyone knows exactly what to do because the policy already defines the process.

Step 2: Detect, Report, and Escalate Incidents Quickly

DORA requires organizations to detect ICT incidents as early as possible and ensure they are reported and escalated through predefined communication channels. The faster an incident is detected, the smaller its impact. This usually involves :

- Monitoring systems 24/7.
- Security alerts.
- SIEM tools (such as Splunk or Microsoft Sentinel).
- Employees reporting suspicious activities.

After detection, the incident must be reported to the correct people. Depending on its severity, it may be escalated to:

- The Security Team
- The Incident Response Team
- IT Management
- Senior Management
- Regulators

Example

- An employee receives a suspicious email asking for banking credentials.
- Instead of ignoring it, the employee reports it using the company's security portal.
- The Security Team investigates and discovers that hundreds of employees received the same phishing email.
- Because the incident was reported quickly, the malicious emails are blocked before anyone clicks the link.
- A small alert prevented a major cyberattack.

Step 3: Perform a Root Cause Analysis (RCA)

Once the incident has been contained, DORA requires organizations to understand why it happened. This is called Root Cause Analysis (RCA). The goal is not only to fix the problem but also to identify its real cause. Typical questions include:

- How did the attacker get in?
- Which control failed?

- Was a software vulnerability exploited?
- Was human error involved?
- Was a supplier responsible?

Example

A company's website becomes unavailable for several hours. At first, everyone believes it was caused by hackers. After the Root Cause Analysis, they discover the real reason:

- A network engineer accidentally deleted an important firewall rule during maintenance.
- The real cause was human error, not cybercriminals.
- Without RCA, the organization might have implemented the wrong solution.

Step 4 : Implement Corrective Actions

Finding the root cause is not enough. DORA requires organizations to implement corrective actions that eliminate or reduce the risk of the incident happening again. Corrective actions may include:

- Installing security patches.
- Updating firewall rules.
- Improving monitoring.
- Changing procedures.
- Training employees.
- Replacing vulnerable systems.

Example

Root Cause: Employees clicked phishing emails.

Corrective Actions:

- Enable Multi-Factor Authentication (MFA).
- Deploy stronger email filtering.
- Provide phishing awareness training.
- Block malicious domains automatically.
- The organization becomes much more resilient against future phishing attacks.

Step 5 : Capture Lessons Learned

Every ICT incident is an opportunity to improve. After the incident is resolved, organizations should organize a Lessons Learned Meeting to review what happened. Typical discussion points include:

- What went well?
- What went wrong?
- Were responsibilities clear?
- Were communication channels effective?
- How can the response be improved next time?

The conclusions should be documented and incorporated into policies, procedures, and training.

Example

During a ransomware attack: Positive findings:

- The Security Team detected the attack within five minutes.

Areas for improvement:

- Some managers did not know whom to contact.
- Employees received inconsistent information.
- Backup restoration took too long.

Improvements:

- Update the Incident Response Plan.
- Improve communication procedures.
- Test backup recovery more frequently.

The organization is now better prepared for future incidents.

Step 6 : Report Significant Incidents

DORA also requires financial entities to report major ICT incidents to the relevant regulatory authorities within the required timelines. Incident reporting ensures that regulators:

- Understand emerging cyber threats.
- Monitor risks affecting the financial sector.
- Coordinate responses when multiple organizations are impacted.

Depending on the incident, organizations may also need to inform:

- Customers
- Business partners
- Service providers
- Shareholders
- Senior management

Example

A payment platform suffers a cyberattack that prevents customers from making online payments. The organization:

- Activates its Incident Response Plan.
- Restores services.
- Reports the major incident to the competent regulator according to DORA requirements.
- Informs affected customers.
- Documents all actions taken.

This demonstrates transparency and regulatory compliance.

16. Information Sharing

Information sharing is one of the key ideas in DORA (Digital Operational Resilience Act). The goal is simple: financial organizations should not fight cyber threats alone. Instead, they should share useful cyber threat information with trusted organizations, regulators, and industry partners so everyone can detect, prevent, and respond to attacks faster.

However, sharing information does not mean sharing everything with everyone. Every organization must protect confidential information, customer data, and business secrets. Information should only be shared through trusted channels, following data protection laws such as GDPR and internal confidentiality rules.

Share Cyber Threat Information with Trusted Partners

- DORA encourages financial institutions to establish secure mechanisms for sharing cyber threat intelligence and incident information with:
- Regulatory authorities
- National cybersecurity agencies
- Financial sector organizations
- Trusted threat intelligence communities
- Industry Information Sharing and Analysis Centers (ISACs)

Example

- A bank discovers a new phishing campaign that steals online banking credentials.
- Instead of keeping this information private, the bank shares it with other banks and the national cybersecurity authority.
- As a result:
- Other banks immediately block the malicious website.
- Security teams warn their customers.
- The attack is stopped before thousands of users become victims.
- Without information sharing: every bank would discover the attack separately.
- With information sharing: everyone becomes protected much faster.

Share Information Securely and Respect Confidentiality

DORA requires organizations to share information responsibly. Never share:

- Customer names
- Passwords
- Banking details
- Personal information
- Trade secrets
- Sensitive internal documents

Instead, organizations share only the technical information needed to stop the attack.

Example

Wrong : "The attacker stole John Smith's account number 123456789."

Correct : "The attacker exploited vulnerability CVE-2026-12345 using malicious IP address 192.168.x.x."

Only the useful security information is shared, not the customer's private data.

Participate in Trusted Information Sharing Communities

DORA strongly encourages organizations to participate in trusted cybersecurity networks where members exchange information about new threats. These communities allow organizations to:

- Learn about attacks earlier.
- Detect threats faster.
- Improve their defenses.
- Protect the entire financial sector.

Example

Suppose one insurance company detects a new ransomware. Within minutes, it informs the financial cybersecurity community. The other companies immediately:

- update their firewalls,
- block malicious IP addresses,
- update antivirus signatures,
- warn their employees.

One company's discovery protects hundreds of organizations.

Share Actionable Cyber Threat Intelligence

The information shared should be **useful** and **actionable**, meaning that other organizations can immediately use it to improve their security. Examples include:

- malicious IP addresses,
- malicious domains,
- malware file hashes,
- phishing email addresses,
- attacker techniques,
- newly discovered vulnerabilities,
- recommended security measures.

Example

Instead of saying: "We suffered a cyberattack." A useful report would say:

- "Attackers used phishing emails pretending to be Microsoft support. They downloaded ransomware from domain xyz-malware.com using IP address 185.xxx.xxx.xxx."
- Now every other organization can immediately block that domain and IP address.

Ensure Shared Information Is Accurate and Timely

Information sharing is only valuable if the information is:

- Accurate
- Verified
- Up to date
- Relevant
- Shared quickly

Incorrect or outdated information can create unnecessary panic or lead organizations to waste time investigating false threats.

Example

- A company discovers that a malicious IP address is attacking financial institutions.
- If it waits three weeks before sharing the information, the attackers may already have changed their infrastructure.
- Sharing the information immediately allows other organizations to block the attack before it spreads.

Establish Internal Policies for Information Sharing

- Organizations should define clear internal rules covering:
- Who can share threat information.
- What information can be shared.
- Who approves the sharing.
- Which trusted partners may receive the information.
- How confidentiality is protected.
- How shared information is stored and documented.

Example

- If a security analyst discovers malware, company policy may require:
 1. Verify the incident.
 2. Inform the Security Manager.
 3. Remove confidential customer data.
 4. Share only technical indicators with the national CERT and banking community.
 5. Archive the report for audit purposes.
- This ensures information is shared consistently, securely, and in compliance with DORA.